AI Privacy & Security Risks

in Higher Education

Implications for Institutional Data Governance

Advisory Briefing for Institutional Leadership

Fernando Alcántar
Director of Student Engagement
Member, AI Recommendation Committee
Doctoral Candidate, Educational Leadership & Administration
East Stroudsburg University | Spring 2026

Why This Matters to CLIE

This is not a general tech briefing.
This is about the data your division handles every day.

- 🧠 Student mental health referrals
- 📋 Identity & accommodation records
- ⚠️ DEI incident reports
- 🔒 Confidential advising notes

Why people don't see the risk: AI interfaces feel conversational — ephemeral, like speaking aloud. There's no visible "send" button. Familiar tools like Word or Excel feel local. The data transfer happens invisibly.

The Core Problem

"The speed at which these tools are being embedded into infrastructure is outpacing the speed at which institutions are developing the frameworks to govern them."

What appears to users as a simple interaction with a tool may, in practice, initiate a chain of external processing events across systems not governed by institutional policy.

Decision-making authority remains internal. Data flows increasingly occur outside institutional boundaries.

The AI Tools in This Briefing

Not all AI tools are the same — here's what each one is and why it appears in this report

ChatGPT

by OpenAI · Conversational AI / LLM

The most widely used AI chatbot. Available on consumer and enterprise accounts. Underpins direct upload risk and the Atlas browser.

Claude

by Anthropic · Conversational AI / LLM

AI assistant built by Anthropic. Embedded in Microsoft 365 as a subprocessor since Jan 2026. Powers Cowork and Dispatch.

Gemini

by Google · Conversational AI / LLM

Google's AI assistant, embedded in Chrome and Google Workspace. CVE-2026-0628 allowed browser extension hijacking of the Gemini panel.

Microsoft Copilot

by Microsoft · AI Layer / Productivity Tool

AI features built into Word, Excel, PowerPoint, and Teams. Powered by OpenAI models — and since Jan 2026, also by Claude via Anthropic subprocessor.

Perplexity

by Perplexity AI · AI Search / Agentic Browser

AI-powered search engine and maker of Comet — one of the first agentic browsers. Demonstrates session inheritance risk across authenticated tabs.

OpenClaw

Open-source · Autonomous Agent Framework

Not an LLM — an autonomous agent that runs on your device and uses Claude or ChatGPT to act. Connects to email, calendars, files, and messaging apps without per-step approval.

How Data Reaches AI: Six Pathways

An escalating spectrum — from deliberate action to autonomous operation across your entire web identity

B.1 Direct Upload
You entered the data deliberately

B.2 Invited Access
AI embedded in your tools

B.3 Automatic Access
No user action required

B.4 Agentic Access
Remote computer control

B.5 Autonomous Agents
AI acting across institutional systems

B.6 Agentic Browsers
Your entire authenticated web identity

← increasing risk · increasing autonomy · decreasing user visibility

B.1

Direct Upload

Data Entered Into AI Tools — the most familiar risk

- A user copies text, pastes a document, or uploads a file into ChatGPT, Claude, or Google Gemini.
- Interacting with an AI chat interface feels conversational — ephemeral, like speaking aloud. But it is a data transfer to an external server.
- Consumer accounts may retain conversations and use them for model training by default (up to five years).
- Student records, grade data, IRB research data, HR communications — none of these categories are exempt because the medium is a chat interface.
- Enterprise accounts offer stronger protections, but most users do not know which type they have.

B.2 Invited Access

AI Embedded in Excel, PowerPoint, and Word

- Copilot, Claude for Excel, Claude for Word, and Claude for PowerPoint operate as plugins inside familiar productivity tools.
- The AI comes to the data — not the other way around. You did not upload anything. The exposure still happens.
- The scope of exposure is determined by what is visible to the AI within the application — an entire workbook, all tabs, all cells.
- This bypasses the psychological friction that once prompted caution. No file was visibly sent. The interaction does not register as a data sharing event.
- Even PowerPoint presentations that use AI-assisted features involve external data processing before content appears on screen.

B.3

Automatic Access

AI Running Inside Microsoft 365 Without User Action

- As of January 7, 2026, Anthropic (Claude) became an enabled subprocessor within Microsoft 365 for most commercial tenants — by default.
- No individual user made a decision to enable this. Most users do not know it is active.
- Features affected: Copilot in Word, Copilot in Excel, Researcher agent, Agent Mode in Excel, Copilot Studio.
- Requests route to Claude's servers — hosted on Amazon Web Services or Google Cloud, not Microsoft's Azure infrastructure.
- Data governed by FERPA, HIPAA, or IRB protocols crosses into third-party infrastructure not under institutional control.
- Technology officers should verify the Anthropic subprocessor toggle status in the Microsoft 365 admin center.

B.4 Agentic Access

Dispatch and Remote Computer Control

- Anthropic's Dispatch (Claude Cowork, March 2026) lets users send instructions from a smartphone. Claude then executes them autonomously on your desktop — while you are not present.
- Claude navigates by taking real-time screenshots of the screen, transmitting those images to external servers to understand the interface.
- Anything visible on screen during task execution is captured and sent — documents, emails, credentials, open files.
- Prompt injection risk: a malicious document or webpage encountered during a task can redirect Claude's actions without the user's knowledge.
- Available on consumer Pro/Max accounts — weaker data protections than enterprise tiers. Anthropic itself advises against use with sensitive data.

B.5

Autonomous Agents

AI Operating Across Institutional Systems

- Agents receive a high-level instruction and execute sequential tasks across multiple connected systems without per-step human approval.
- Tools include Claude Cowork, Microsoft Copilot Agents, OpenAI Operator, Google Gemini agents, and OpenClaw.
- The "lethal trifecta": access to private data + ability to communicate externally + ability to process untrusted content. Most agents meet all three by default.
- A single prompt injection can trigger a chain of compounding autonomous actions — deleting files, forwarding communications, submitting forms — before any human is aware.
- Shadow AI risk: employees connecting personal agent tools to institutional email, calendars, or LMS grant persistent access that survives banning the tool.

B.6 Agentic Browsers

AI Across Your Entire Authenticated Identity

- Agentic browsers (ChatGPT Atlas, Gemini in Chrome, Perplexity Comet) operate across a user's entire authenticated web identity simultaneously.
- Session inheritance: the AI inherits permissions across every system the user is logged into — email, SIS, LMS, HR portal — all at once.
- Tab isolation — the core security boundary of the modern web — no longer applies. A single malicious prompt can cascade across every open tab.
- OpenAI's own CISO: prompt injection "remains a frontier, unsolved security problem."
- CVE-2026-0628 (Gemini in Chrome, CVSS 8.8): a malicious extension could access camera, microphone, and local files via the Gemini panel. Directly affects Google Workspace and Chrome environments.

Six Pathways: At a Glance

Each mechanism differs in who initiates it, how visible it is, and what it puts at risk

Mechanism	Initiator	Visible to User	Primary Risk
Direct Upload	User	**High**	Explicit data transfer
Embedded AI (Copilot, Claude)	User (indirect)	**Medium**	Expanded, implicit data scope
Automatic AI (M365)	System / Admin	**Low**	Invisible background processing
Agentic Access (Dispatch)	User (delegated)	**Low**	Full environment exposure
Autonomous Agents	AI system	**Very Low**	Compounding cross-system actions
Agentic Browsers	AI + identity	**None**	Simultaneous multi-system access

Real Incidents: It's Already Happening

Samsung Source Code Leak

Engineers pasted proprietary code into ChatGPT on consumer accounts. Retained for model training. Samsung banned all external AI tools.

EchoLeak — Zero-Click Copilot Exfiltration

A malicious email caused Copilot to silently pull data from OneDrive, SharePoint & Teams. No user action required. No alerts generated.

Chat & Ask AI — 380M Messages Exposed

AI wrapper app left its Firebase database fully public. 18M user records. No authentication required to read, modify, or delete.

OpenClaw Agent Crisis

9 critical CVEs in 4 days. 820+ malicious marketplace skills. 42K exposed instances. Cisco called it "a security nightmare."

What This Means for Your Data

CLIE handles data with FERPA protection. That protection does not automatically follow data into an AI system.

- Student mental health and wellness records
- DEI incident reports and case documentation
- Accommodation and disability documentation
- Student identity and demographic data
- Confidential advising notes and referrals

Any of these categories, entered into or processed by AI on a personal account, may leave ESU's data governance entirely — with no audit trail and no recourse.

The Account Type Problem

Most people don't know which type of account they're using — or why it matters.

CONSUMER ACCOUNT	ENTERPRISE ACCOUNT
✗ Free, Pro, or similar tiers	✓ Institutional / organizational tier
✗ Conversations may be retained	✓ No training on your data
✗ Data may be used for model training	✓ Data not retained beyond session
✗ Weaker contractual protections	✓ Contractual protections in place
✗ Most users are on this tier	✓ Requires institutional license

If you use ChatGPT, Claude, or Gemini with a personal login — you are almost certainly on a consumer account.

What ESU Is Doing About It

1

AI Recommendation Committee (AIRC)

Active institutional body developing governance frameworks for AI use at ESU.

2

This Report

AI Privacy & Security Risks briefing — synthesizing the current threat landscape for institutional leaders.

3

Dissertation Research

Doctoral-level investigation into AI policy, data governance, and educational leadership implications.

4

MSCHE Alignment

ESU's AI work is framed within MSCHE's July 2025 AI procedures — human-in-the-loop principle, institutional accountability.

A Tiered Response Framework

Recommended actions organized by urgency and institutional scope

0-30 Days

Immediate Risk Mitigation

- Audit Microsoft 365 admin center — confirm Anthropic subprocessor status
- Clarify ESU tenant classification (commercial vs. education tier)
- Establish Shadow AI policy for personal account use

30-90 Days

Structural Policy Alignment

- Update AI use policies to cover embedded and automatic AI access
- Classify agentic tools (Dispatch, OpenClaw, Copilot Studio) as high-risk
- Audit OAuth integrations and revoke unauthorized agent access
- Define institutional stance on agentic browsers

90+ Days

Strategic Capacity Building

- Develop training on AI data flows and the perception gap
- Integrate AI governance into faculty and staff onboarding
- Communicate consumer vs. enterprise account distinctions broadly

Questions & Discussion

Fernando Alcántar

Member, AI Recommendation Committee
Doctoral Candidate, Educational Leadership & Administration
East Stroudsburg University | Spring 2026

Full report available upon request